Nociones generales sobre Seguridad de la Información

Generalidades : ¿qué es seguridad?

- Podemos entender como seguridad una característica de cualquier sistema (informático o no) que nos indica que ese sistema está libre de todo peligro, daño o riesgo, y que es, en cierta manera, infalible.

Generalidades: aspectos de la seguridad

- A grandes rasgos se entiende que mantener un sistema seguro (o fiable) consiste básicamente en garantizar tres aspectos:
  - confidencialidad,
  - integridad y
  - disponibilidad.

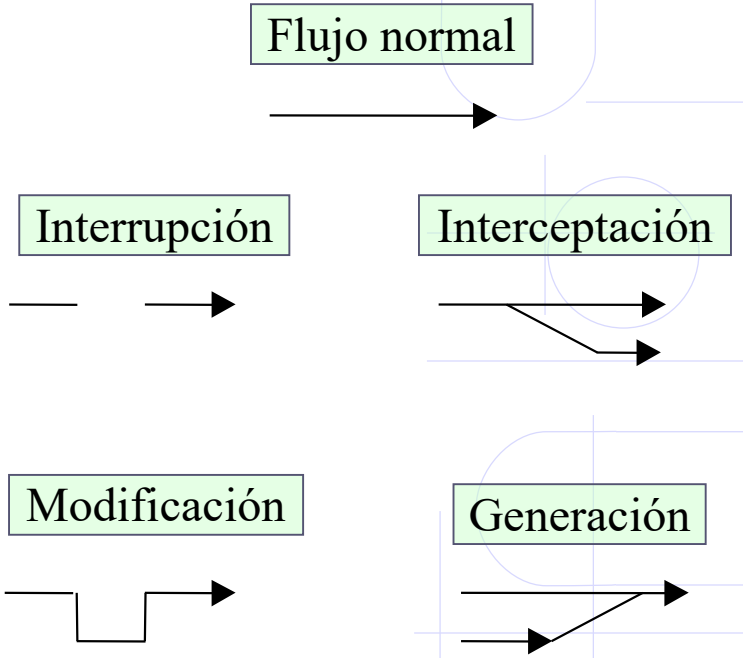
Generalidades: elementos de la seguridad

- Los tres elementos principales a proteger en cualquier sistema informático son:
  - el hardware,
  - el software y
  - los datos.

Generalidades: amenazas a la seguridad

- Contra cualquiera de los tres elementos (pero principalmente sobre los datos) se pueden realizar multitud de ataques o, dicho de otra forma, están expuestos a diferentes amenazas.

- Generalmente, la clasificación más elemental de estas amenazas las divide en cuatro grandes grupos:
  - interrupción,
  - interceptación,
  - modificación
  - generación.



Generalidades: mecanismos de seguridad

Los mecanismos de seguridad de un sistema se dividen en tres grandes grupos:

- Prevención
- Detección
- Recuperación.

PREVENCIÓN

- Los mecanismos de **prevención** son aquellos que aumentan la seguridad de un sistema durante el funcionamiento normal de éste, previniendo la ocurrencia de violaciones a la seguridad;
  - **por ejemplo**, el uso de **cifrado** en la transmisión de datos se puede considerar un mecanismo de este tipo, ya que evita que un posible atacante escuche las transmisiones de información que circulen por la red.

DETECCIÓN

- Por mecanismos de **detección** se conoce a aquellos que se utilizan para detectar violaciones de la seguridad o intentos de violación;
  - ejemplos de estos mecanismos son son los sistemas de detección de intrusiones (IDS - *Intrusion Detection System*).

RECUPERACIÓN

- Finalmente, los mecanismos de **recuperación** son aquellos que se aplican cuando una violación del sistema se ha detectado, para retornar a éste a su funcionamiento correcto;
  - ejemplos de estos mecanismos son la utilización de copias de seguridad o el hardware adicional.

Generalidades: mecanismos de prevención

- Aunque los tres tipos de mecanismos son importantes para la seguridad de un sistema, se debe enfatizar en el uso de mecanismos de prevención y de detección;
  - la máxima popular "más vale prevenir que curar" se puede aplicar a la seguridad de los datos.

- Los mecanismos de prevención más habituales son los siguientes:
  - Mecanismos de autenticación e identificación
  - Mecanismos de control de acceso
  - Mecanismos de seguridad en las comunicaciones

MECANISMOS DE SEGURIDAD EN LAS COMUNICACIONES

- Es especialmente importante para la seguridad de un sistema proteger la confidencialidad y la integridad de la información que se transmite a través de la red.

- Para garantizar la seguridad en las comunicaciones, se debe hacer uso de mecanismos que se basan en la **Criptografía** (cifrado de clave pública, de clave secreta, firmas digitales, …)

- No hay una única herramienta global criptográfica si no que existen distintas técnicas para lograr distintos objetivos, como
  - cifrar mensajes,
  - intercambio seguro de claves criptográficas,
  - mantener y asegurar la integridad de un mensaje así como
  - garantizar la autenticidad de un mensaje recibido.

Introducción histórica

- La criptografía clásica abarca desde tiempos inmemoriales hasta la mitad del siglo XX, época a partir de la cual se considera criptografía moderna.

- El punto de inflexión en esta clasificación (clásica vs. moderna) lo marcan tres hechos relevantes:

  - En el año 1948 se publica el estudio de C. Shannon sobre la Teoría de la Información.
  - En 1974 aparece el estándar de cifrado DES.
  - En el año 1976 se publica el estudio realizado por W. Diffie y M. Hellman sobre la aplicación de funciones matemáticas de un solo sentido a un modelo de cifra, denominado cifrado con clave pública.

Cifrado digital

Terminología

- Aunque nos hemos referido ya a algunos términos, daremos a continuación un pequeño vocabulario específico.

CIFRAR-DESCIFRAR

- Cuando deseamos enviar un mensaje de manera que resulte incompresible para aquellas personas a las que no va dirigido utilizando determinada técnica, diremos que ***ciframos*** el mensaje. El destinatario del mismo debe ***descifrarlo*** utilizando esa misma técnica.

MODELO HISTÓRICO MENCIONADO EN ESTA INTRODUCCIÓN GENERAL

CIFRADO DE JULIO CÉSAR

- El historiador romano Suetonio, contemporáneo de Plutarco, nos describe un sistema de ***cifrado*** utilizado por ***Julio César*** (siglo I a.C.):
  - "...Para quienes deseen saber más diré que sustituía la primera letra del alfabeto, A, por D y así sucesivamente con todas las demás...".

A	B	C	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	V	X
D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	V	X	A	B	C

Ejemplo

- La frase que pronunció Julio César en una expedición militar cuando tras bajarse de una barca cayó de bruces: TENEO TE AFRICA

  en lenguaje cifrado se escribe como: AHQHR AH DIVMFD

TEXTO EN CLARO-CRIPTOGRAMA

- Un mensaje que se desea cifrar es llamado ***texto en claro*** o ***texto plano***, una vez cifrado se dice que es un ***criptograma***.
  - Para cifrar un texto en claro normalmente se suele dividir en bloques de una longitud preestablecida, que a veces consisten en un sólo carácter. Así, cada bloque m de texto plano es convertido en un bloque de texto cifrado c.
  - Denotaremos este proceso con la letra E y lo representaremos como E(m)=c, por ejemplo en el método utilizado por Julio César

$$E(A)=D,\ E(B)=E,\ldots,E(X)=C$$

  - El proceso de descifrado lo expresaremos con D. En el cifrado de César, por ejemplo, denotaremos

$$D(D)=A,\ D(E)=B,\ldots,D(C)=X$$

- Por supuesto, resulta esencial que el proceso de descifrado sea opuesto al de cifrado, esto es

$$D(E(m))=m$$

CRIPTOSISTEMA-CLAVE

- Una función cifradora E junto con su correspondiente función descifradora D es conocido como un ***criptosistema o sistema criptográfico***.
- El cifrado y descifrado de los mensajes regularmente requiere de una pieza especial para el conocimiento del criptosistema conocida como ***clave***.
  - Por ejemplo, en el método de J. César la clave es la cantidad con la que cada letra es desplazada a la derecha o izquierda dentro de la tabla

A	B	C	D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	V	X
D	E	F	G	H	I	K	L	M	N	O	P	Q	R	S	T	V	X	A	B	C

  - Con ese número podemos conocer el orden para cifrar y descifrar los mensajes.

CRIPTOGRAFÍA-CRIPTOANÁLISIS

- La ciencia que estudia el diseño de criptosistemas es conocida como ***criptografía***.
- En la creación de un criptosistema se debe tener como objetivo que una persona no autorizada, que no conozca la clave, no pueda descifrar los mensajes.
- Las personas que intentan descifrar mensajes sin conocer la clave son conocidos como ***criptoanalistas*** y la ciencia que intenta romper los criptosistemas, descifrando en un tiempo razonable el contenido de un mensaje sin conocer la clave, es llamada ***criptoanálisis***.

CRIPTOLOGÍA

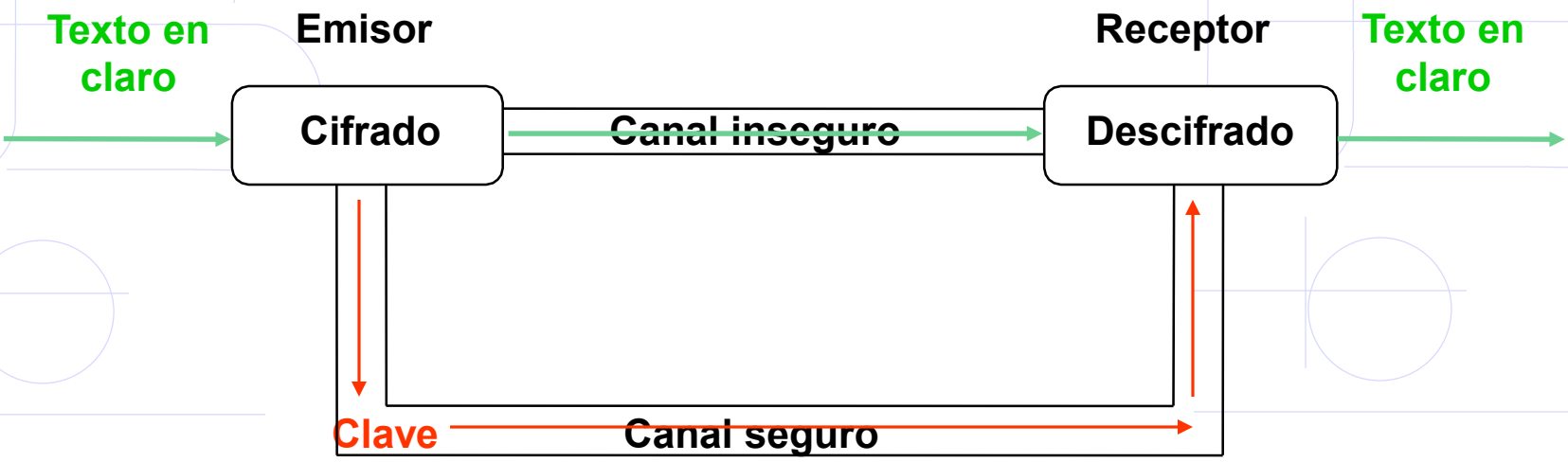
- Los campos de la criptografía y el criptoanálisis, son conocidos en su conjunto como ***criptología***.

ESPACIO DE CLAVES

- El componente fundamental del criptosistema del que carece el criptoanalista es la clave.
  - El objetivo de este último es descubrir la clave correcta de entre el conjunto K de todas las posibles a utilizar, este conjunto es conocido como el ***espacio de claves***.

- El criptoanalista puede conocer, por ejemplo, que el criptosistema es un método de cifrado tipo César pero desconocer el número de posiciones que es desplazada cada letra.
  - Su meta es averiguar la clave utilizada dentro del espacio $K=\{1,2,...,21\}$.

ESQUEMA DE UN SISTEMA DE CIFRADO



Clasificación

- Podemos realizar varias ***clasificaciones*** de los criptosistemas, atendiendo a diversos criterios.

ANTIGUEDAD

- **Clásicos**: Si su origen es anterior a la aparición del ordenador.
- **Modernos**: Se fundamentan en la informática. Necesitan ser actualizados (en muchos casos son desestimados) al ritmo de progreso de la potencia de cálculo de los ordenadores.

FORMA DE CIFRAR

- **Cifrado en bloque**: El mismo algoritmo de cifrado se aplica a un bloque de información (grupo de caracteres, número de bytes, etc.) repetidas veces, usando la misma clave.
- **Cifrado en flujo**: El algoritmo de cifrado se aplica a un elemento de información (carácter, bit) mediante un flujo de clave en teoría aleatoria y mayor que el mensaje.

Clasificación

IGUALDAD ENTRE LAS CLAVES DE CIFRADO Y DESCIFRADO

- **Simétricos**: La clave de descifrado es la misma que la del cifrado o se puede obtener a partir de ella.
- **Asimétricos**: Las claves de cifrado y descifrado son distintas y no puede obtenerse una a partir de la otra, salvo que se disponga de alguna información adicional.

CONOCIMIENTO DE LA CLAVE

- **De clave privada o secreta**: Las claves de cifrado y descifrado sólo son conocidas por personal autorizado.
- **De clave pública**: El conocimiento de la clave de cifrado se puede hacer pública, pero la de descifrado sólo es conocida por el receptor del mensaje.

Números grandes

- Los actuales algoritmos criptográficos emplean claves con un elevado número de bits, y usualmente se mide su calidad por la cantidad de esfuerzo computacional que se necesita para romperlos.

- El tipo de ataque mas simple es la ***fuerza bruta***, que simplemente trata de ir probando una a una todas las claves.
  - Por ejemplo, el algoritmo DES tiene 2^{56} posibles claves.
  - ¿Cuanto tiempo nos llevaría probarlas todas si, por ejemplo, dispusiéramos de un computador capaz de probar un millón de claves por segundo?

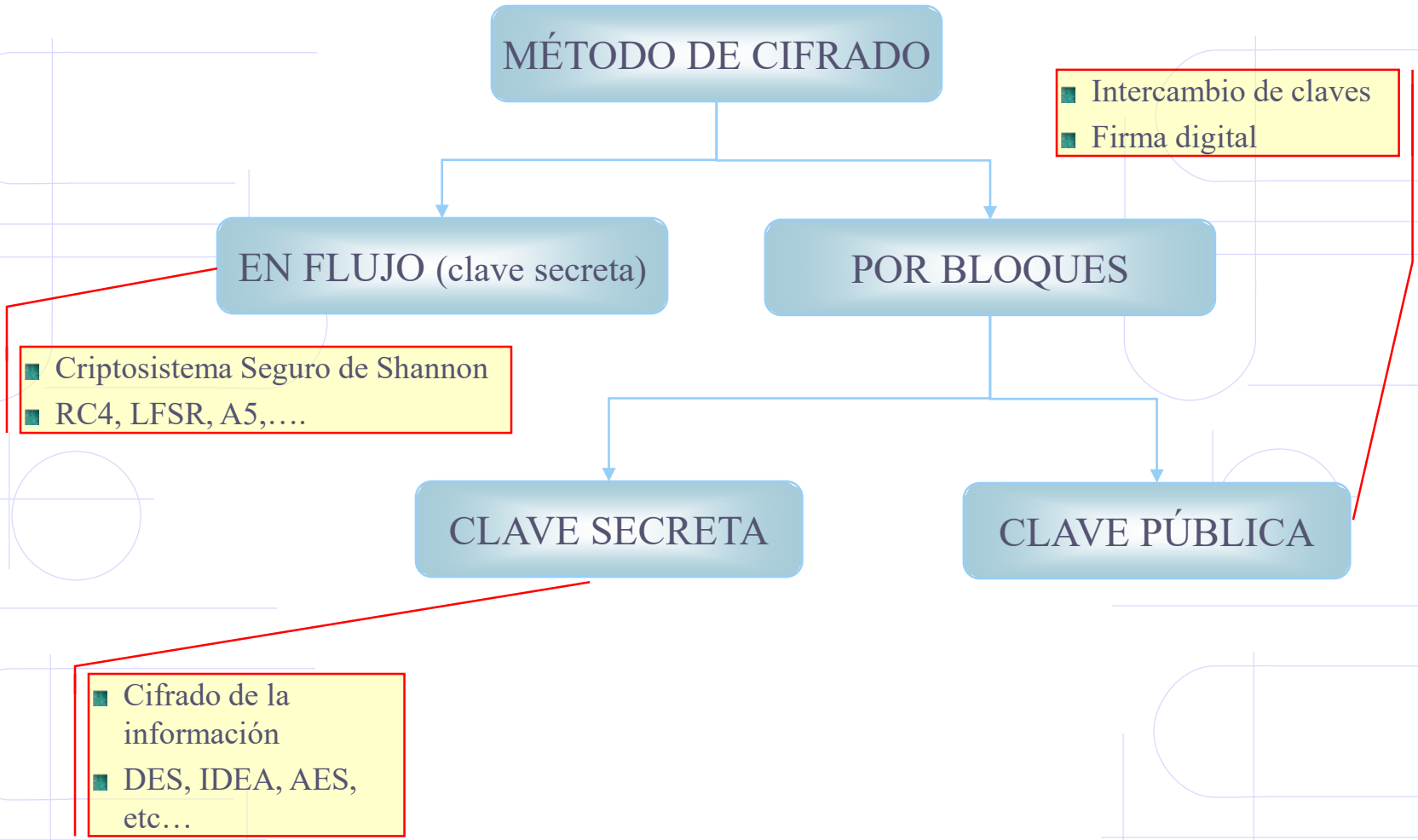
    Tardaríamos más de 2200 años
  - Si la clave tuviera 128 bits, el tiempo requerido sería de 10^{24} años, que es aproximadamente cien billones de veces la edad del universo.

- Este dato nos debe disuadir de emplear mecanismos basados en la fuerza bruta para *reventar* claves de 128 bits.

Introducción a criptosistemas modernos

- Cuando se habla de **criptografía moderna** o criptosistemas modernos, en contraposición a los denominados clásicos, se hace referencia a aquellos sistemas de cifrado, bien de clave secreta, bien de clave pública, que
  - por una parte, **realizan el cifrado en bits,** por lo general, mediante operaciones algebraicas dentro de un cuerpo finito.
  - y por otra, **basan su seguridad en la fortaleza de la clave** y no en el secreto de un algoritmo de cifrado.

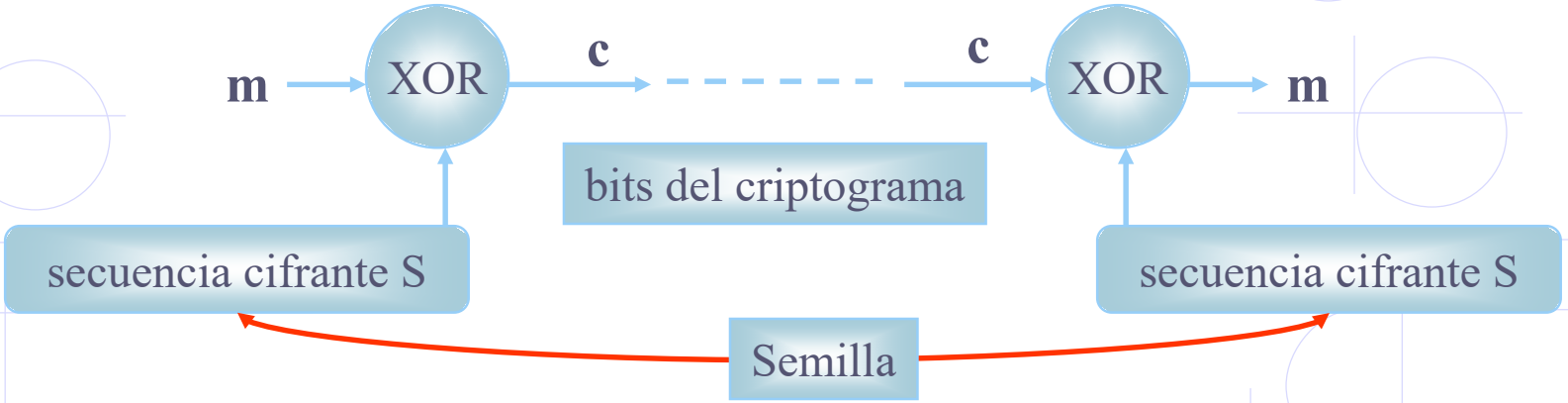
Clasificación de los criptosistemas modernos



Cifrado en flujo

- El mensaje en claro se lee bit a bit.
- Se realiza una operación de cifrado (normalmente la función XOR) con una secuencia cifrante de bits S que debe cumplir ciertas condiciones:
  - Un período muy alto.
  - Aleatoriedad en sus propiedades.

Esquema



ALGORITMOS DE CIFRADO EN FLUJO

- Entre los sistemas de cifrado en flujo más conocidos y utilizados destacamos:
  - RC4: Algoritmo de RSA, Rivest Cipher #4, desarrollado en el año 1987.
  - SPRITZ: variante mejorada de RC4 desarrollada en 2014.
  - Salsa20: uno de los algoritmos ganadores de eSTREAM PROJECT
  - A5: Algoritmo no publicado propuesto en 1994. Versiones A5/1 fuerte (Europa) y A5/2 débil (exportación). Utilizado para cifrar el enlace en la telefonía móvil GSM (Global Systems for Mobile communications) o telefonía 2G.
  - SNOW 3G, núcleo de la integridad y la confidencialidad de las comunicaciones 4G
  - E0, algoritmo utilizdo en el cifrado de la información transmitida mediante tecnología Bluetooth.

Cifrado en bloque con clave secreta

- El texto en claro se fracciona en bloques de un tamaño constante y se aplica, con la misma clave, el algoritmo a cada bloque de forma independiente.

- El cifrado se realiza con una clave secreta

- Algunos de los más conocidos son
  - **DES** (*Data Encryiption Standard)* por su uso en aplicaciones bancarias.
  - **AES** (*Advanced Encryption Standard*): nuevo estándar avanzado de cifrado del Instituto Nacional de Estándares y Tecnología (National Institute of Standards and Technology, NIST) ***(Rijndael)***

Cifrado en bloque con clave secreta

ALGORITMOS MÁS UTILIZADOS

- AES
- DES (Triple DES)
- Serpent
- Blowfish, Twofish

OTROS ALGORITMOS

- Camellia
- CAST-128
- IDEA
- RC2, RC5, RC6
- SEED
- ARIA
- Skipjack
- TEA, XTEA

Modos de cifrado en bloque

- Se ha convenido en denominar al uso directo de un cifrador en bloque como modo de «Libro Electrónico de Códigos» (*Electronic Codebook*, **ECB**).

- Entre otros, el NIST (U.S. National Institute for Standards and Technology) recomienda cuatro modos de uso, tanto para AES como para cualquier cifrado en bloque:
  - Encadenamiento de bloques cifrados (*Cipher Block Chaining*,**CBC**)
  - Realimentación del texto cifrado (*Cipher Feedback*, **CFB**)
  - Realimentación de la salida (*Output Feedback*, **OFB**)
  - Modo contador (*Counter mode*, **CTR**)

Debilidades del cifrado con clave secreta

- **Mala gestión de claves:** para una red de n usuarios el número de claves es $O(n^2)$. Para un número grande de usuarios es intratable👎.
- **Mala distribución de claves:** no existe posibilidad de enviar, de forma segura, una clave a través de un medio inseguro👎.
- **No tiene firma digital:** aunque es posible autentificar el texto en claro mediante una marca, no es posible firmarlo digitalmente👎.

Mala gestión de claves 👎.
Mala distribución de claves 👎.
No tiene firma digital 👎.

¿Tiene algo de bueno el cifrado en bloque con clave secreta?

Sí, la velocidad de cifrado es muy alta 👍

Cifrado con clave pública

- Uno de los mayores **inconvenientes** que presentan los sistemas de clave secreta cuando existe un gran número de usuarios es que cada par de ellos debe poseer su clave secreta, lo que conlleva gran dificultad en la **distribución** segura de esas **claves**.

- Otro gran **inconveniente** es que no se puede **firmar digitalmente** el mensaje, con lo que el receptor del mismo no puede estar seguro de su autenticidad (o sea, no puede estar seguro de que quien dice que le envía el mensaje sea realmente quien lo ha hecho)

Cifrado con clave pública

- Un criptosistema de clave pública permite la comunicación cifrada entre dos usuarios sin necesidad de compartir una clave, así como la firma digital de los mensajes.

- Los algoritmos de clave pública, o algoritmos asimétricos, han demostrado su interés para ser empleados en redes de comunicación inseguras (Internet)

- Introducidos por Whitfield Diffie y Martin Hellman a mediados de los años 70, su novedad fundamental con respecto a la criptografía simétrica o de clave secreta es que las claves no son únicas, sino que forman pares con la propiedad de que una es capaz de descifrar lo que ha sido cifrado por la otra.

Cifrado con clave pública

- Los algoritmos asimétricos, por lo general, basan su seguridad en el enfrentamiento del atacante a problemas matemáticos que requieren mucha computación.

- Emplean, generalmente, longitudes de clave mucho mayores que los simétricos.
  - Por ejemplo, mientras que para algoritmos simétricos se considera segura una clave de 128 bits, para algoritmos asimétricos (si exceptuamos aquellos basados en curvas elípticas) se recomiendan claves de al menos 1024 bits.

- La complejidad de cálculo que comportan los hace considerablemente más lentos que los algoritmos de cifrado simétricos.

- ***En la práctica los métodos asimétricos se emplean únicamente para cifrar la clave de sesión (simétrica) de cada mensaje o transacción particular***.

Cifrado con clave pública

- Fijadas las dos claves de cada usuario como clave pública y clave privada.
- La clave privada deberá ser custodiada por el usuario y es imprescindible que se mantenga en secreto.
- La clave pública, por el contrario, se publicará junto con la identidad del usuario.
- Así, cuando se quiera enviar un mensaje seguro a un usuario se hará uso de la clave pública, que se utilizará para cifrar el mensaje a enviar.

Cifrado con clave pública

- El resultado de esta operación será el texto cifrado que sólo el propietario de la clave privada correspondiente a esa clave pública podrá descifrar.

- Estas claves tienen características matemáticas especiales.
  - Se generan siempre a la vez, por parejas, estando cada una de ellas ligada intrínsecamente a la otra,
  - de tal forma que si dos claves públicas son diferentes, entonces sus claves privadas asociadas también lo son y viceversa.

Cifrado con clave pública

- En este tipo de ciptosistemas, para enviar un mensaje con seguridad, el emisor (A) cifra el mismo con la clave pública del receptor (B) y lo envía por el medio inseguro.

- Este mensaje está totalmente protegido en su viaje, ya que sólo se puede descifrar con la clave privada correspondiente, conocida solamente por B.

- Al llegar el mensaje cifrado a su destino, el receptor usa su clave privada para obtener el mensaje en claro.

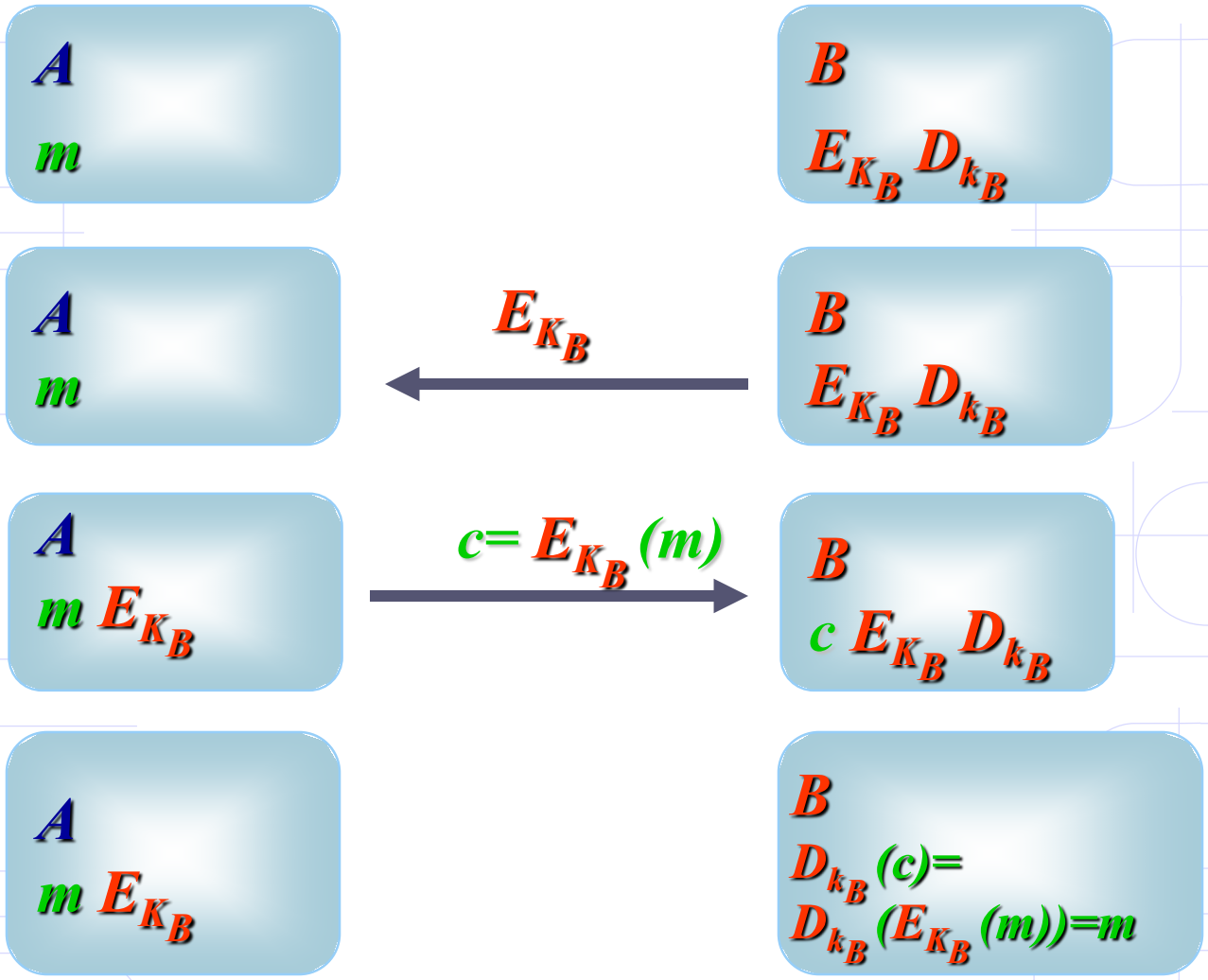
- El algoritmo más utilizado es **RSA**

Cifrado con clave pública

K_B = clave pública de B

k_B = clave privada de B

CRIPTOSISTEMA DE CLAVE PÚBLICA



Ejemplo de proyecto

Hyper Desktop

Servidor de contenidos multimedia en la nube con cifrado

Funcionamiento

- Hyper Desktop es un servidor de contenidos multimedia en la nube en el que se cifran tanto la conexión entre el servidor y el cliente como los datos almacenados en el servidor por lo que este no puede tener acceso al contenido de los mismos aun cuando los almacena.

- El cliente se conecta a través de una aplicación de escritorio desarrollada en Java.

- El servidor almacena, además de los archivos, algunos datos necesarios para la aplicación.

Datos

- ID: Cada archivo tiene una ID propia para poder identificarlo, que está relacionada con el usuario al que le pertenece.
- User: Se utiliza para identificar al usuario.
- Password: Será necesaria una contraseña de 16 caracteres mínimo, con al menos una mayúscula y un número.
- Archivos cifrados: Los archivos a subir serán cifrados en el cliente, tras lo que serán subidos al servidor. Por lo que este en ningún momento tendrá acceso al contenido de los mismos.
- Una serie de claves que se explicarán detalladamente a continuación.

Algoritmos

- Algoritmo simétrico: El algoritmo simétrico elegido es AES con una longitud de clave de 128 bits.

- Algoritmo asimétrico: El algoritmo asimétrico elegido es RSA, con una longitud de clave de 1024 bits. Que aunque no sea el estándar de forma oficial, si que es el estándar de facto y también seguro a día de hoy.

Notación cifrado

- **Usuario u**
  - Clave privada RSA del usuario u: k_u^{RSA}
  - Clave pública RSA del usuario u: K_u^{RSA}
- **Usuario v**
  - Clave privada RSA del usuario v: k_v^{RSA}
  - Clave pública RSA del usuario v: K_v^{RSA}
- **Fichero File**
  - Clave AES para el fichero f: k_f
- **Password**
  - Contraseña del usuario u: p_u
  - Contraseña del usuario v: p_v

Registro

- El usuario u que desee registrarse, necesitará:
  - Un Nick
  - Un *password* de 16 caracteres al menos: p_u
  - Un par de claves pública/privada que será generado por el programa del cliente.

- Los pasos a seguir son:
  - El usuario u solicita al servidor registrarse.
  - Una vez el servidor haya autorizado al usuario u su registro, este generará un par de claves pública y privada : K_u^{RSA} / k_u^{RSA}
  - El usuario u envía la clave pública tal cual: K_u^{RSA}
  - El usuario u envía la clave privada encriptada con su contraseña: $E_{p_u}^{AES}(k_u^{RSA})$

- De esta forma, el servidor dispondrá de todo lo necesario para que el usuario u opere pero al mismo tiempo no dispondrá de la contraseña en sí que es el desencadenante de todos los servicios que ofrece.

Subir un archivo

El usuario u quiere subir un archivo f para lo que

- Genera una clave AES que será única para ese archivo: k_f
- Cifra el fichero f con dicha clave: $E_{k_f}^{AES}(f)$
- Cifra la clave del fichero con su clave pública: $E_{K_u^{RSA}}^{RSA}(k_f)$
- Y sube los dos elementos generados: $E_{k_f}^{AES}(f)$ $E_{K_u^{RSA}}^{RSA}(k_f)$
  - De esta forma el servidor ha recibido el archivo f cifrado con AES y la clave AES utilizada, cifrada con RSA mediante la clave pública de u; de manera que el conocimiento del servidor tanto del contenido archivo f como de la clave AES utilizada para su cifrado es nulo.

Descargar archivo privado

Si el usuario u desea descargar un archivo f

- Se descargará el archivo cifrado, $E_{k_f}^{AES}(f)$, y la clave AES de este cifrada con su clave pública $E_{K_u^{RSA}}^{RSA}\left(k_f\right)$
- Una vez descargado, descifra la clave AES del fichero:
  - $D_{k_u^{RSA}}^{RSA}\left[E_{K_u^{RSA}}^{RSA}\left(k_f\right)\right] = k_f$
- Y una vez tenga la clave AES del fichero, lo descifra:
  - $D_{k_f}^{AES}\left[E_{k_f}^{AES}(f)\right] = f$
- Y ya habrá conseguido el archivo que deseaba.

Compartir archivos

- Escenario:
  - el usuario u tiene un fichero f ya subido al servidor que desea compartir con el usuario v.

- u se descarga del servidor la clave AES del archivo f y recibe:
  - $E_{K_u^{RSA}}^{RSA}\left(k_f\right)$

- Como u dispone de su clave privada RSA, k_u^{RSA}, lo descifra y obtiene la clave del archivo:
  - $D_{k_u^{RSA}}^{RSA}\left[E_{K_u^{RSA}}^{RSA}\left(k_f\right)\right] = k_f$

Compartir archivos

- Una vez ha obtenido k_f , le solicita al servidor la clave pública del usuario v y cifra la clave del fichero con la clave pública de v:
  - $E^{RSA}_{K_v^{RSA}}\left(k_f \right)$

  y lo sube al servidor.

- Cuando el usuario v desee descargar dicho archivo, se descargará la clave que se ha generado a partir de su clave pública y será capaz de conseguir la clave AES del archivo f:
  - $D^{RSA}_{k_v^{RSA}}\left[E^{RSA}_{K_v^{RSA}}\left(k_f \right) \right] = k_f$

Ejemplo de 1ª memoria: PROGRAMACION AES

- javax.crypto.KeyGenerator
- javax.crypto.Cypher
- javax.crypto.spec.SecretKeySpec

Ejemplo de 1ª memoria: PROGRAMACION RSA

- java.security.KeyPair
- java.security.KeyPairGenerator
- java.security.PrivateKey
- java.security.PublicKey